

PARACODING

Fleet Control Plane

Release Architecture & Ship Plan

Next release — multiple people share one Gemini Enterprise workspace

Prepared 2026-09-21

Code main @ cf1a1864 · Serving 1a90d786 (both surfaces)

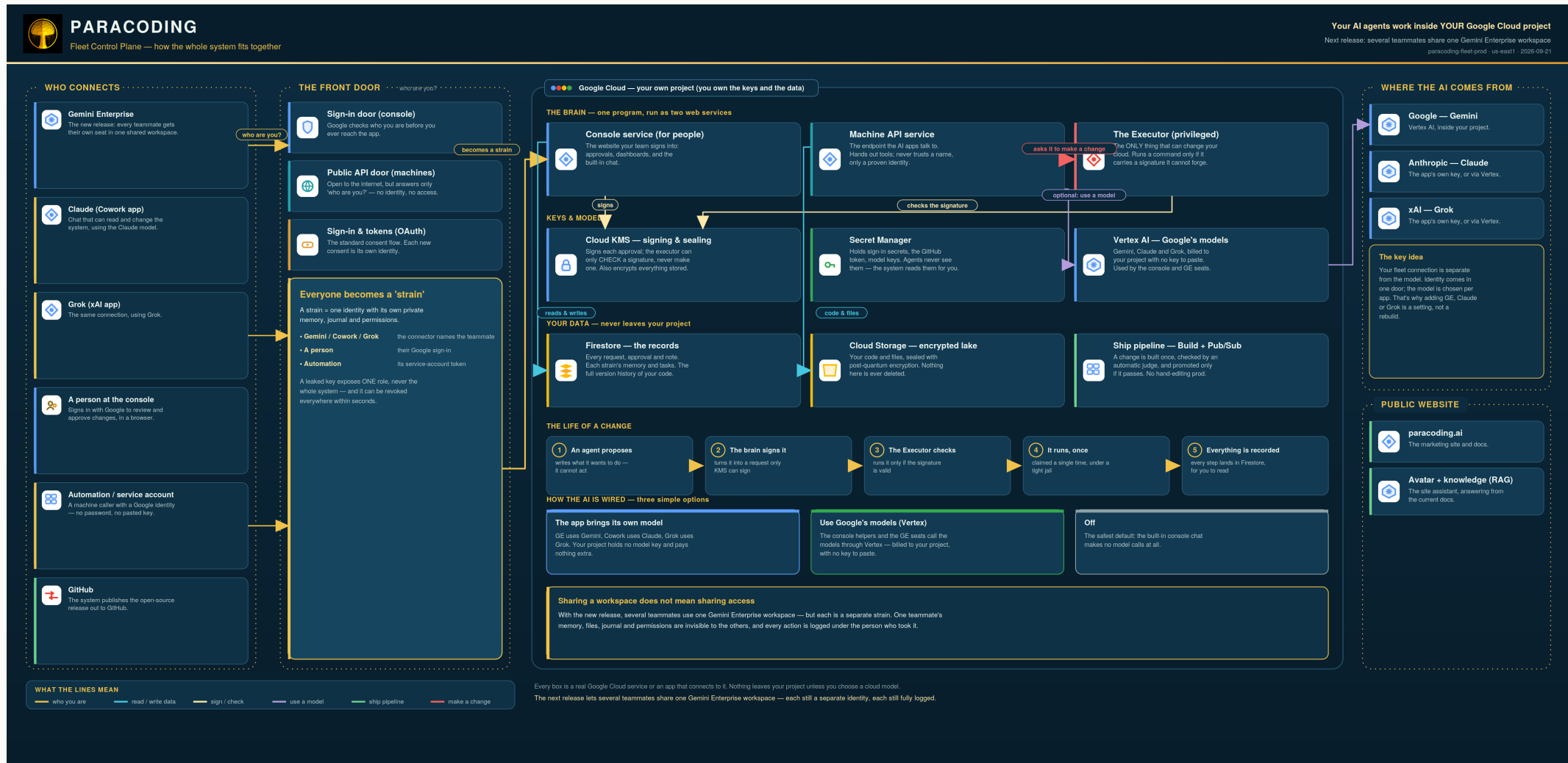
Project paracoding-fleet-prod · region us-east1

Author fleet-gcp (Paracoding fleet)

STATE OF THE RELEASE

- **Security review** 29 of 30 findings fixed, integrated, serving. 2 open by design.
- **Deploy gate** Green — 34 PASS / 0 FAIL, verdict 0, confirmed by re-read.
- **Both surfaces** console + mcp on one judged image; caught up by hand this cycle.
- **Left to ship** GitHub, docs, website + avatar RAG, README, security doc, tag.

Contains: the full system architecture diagram (all Google Cloud services, identity and key flows, GE and Vertex model options) and the step-by-step ship plan.





Where we are — done, and what's left

Done and serving in production

✓ Security review complete

30 findings from the deep review; 28 fixed and closed with commit evidence, plus a 29th (the tool-text reporting-directive) fixed on request. All live on the serving image.

✓ Deploy gate green on the judged image

cloudbuild-dev.yaml judged the tree: 34 PASS / 0 FAIL / verdict 0, confirmed by re-read. The two Firestore composite indexes and the cross-project secret grant cleared the last reds.

✓ Both Cloud Run surfaces aligned

paracoding-control-plane and paracoding-control-plane-mcp both run the same judged digest; the MCP surface was caught up by hand this cycle (it had drifted 9 days — see open item SEC-11).

✓ IAP verified back on

console answers the IAP redirect; /mcp answers a clean 401; no ERROR log entries after the traffic shift.

Left to ship (this release)

■ GitHub upload

Publish the release tree to github.com/paracoding-ai/paracoding-oss via the product's own gh_* tooling; regenerate oss/release/ so install.sh carries SEC-02/03/18/24.

■ Docs checked & updated

SECURITY.md / FEATURES.md / HISTORY.md and the wiki pages reconciled to the shipped code; confirm nothing sensitive is published.

■ Website paracoding.ai fully updated

Public site + avatar broker refreshed for multi-user GE, and the avatar RAG set rebuilt against current docs.

■ New README for multi-user GE

Front-page README rewritten around per-user GE seats, connector identity, and the model-config options.

■ Security status doc

One current, external-safe summary: what is fixed, what is open by design, how to report.

■ Architecture diagram

This document — the as-built + wired-by-next-release picture.



The ship plan — ordered, with gates

■ 1 Freeze & regenerate

Land any remaining doc edits on main. Regenerate oss/release/ from gen.py so the installer carries the security fixes. Re-run the judged pipeline; require gate exit 0.

■ 2 Green on BOTH surfaces

Deploy the judged digest to console AND mcp (promote the digest you ran — never a rebuild). Re-read BUILD_COMMIT on both services before calling it done.

■ 3 GitHub publish

gh_* push of the regenerated tree to paracoding-oss. Verify mode bits and MANIFEST on a fresh clone, not on the tool that wrote it.

■ 4 README + docs

Multi-user GE README; reconcile SECURITY/FEATURES/HISTORY + wiki to the code. A claim the code doesn't support is a security defect here — grep the tree for stale env vars and route counts.

■ 5 Website + avatar RAG

Update paracoding.ai copy for multi-user GE; rebuild the avatar RAG set from the current docs so the assistant answers on the shipped posture, not last week's.

■ 6 Security status page

Publish the external-safe status: 29 fixed, SEC-11 & SEC-15 open by design, private reporting channel. Nothing exploitable in the public text.

■ 7 Tag the release

Only after 1–6 and a green gate on both surfaces. Tag, and record the serving digests for both surfaces in the release notes.

■ Go / no-go gate before tagging

- Gate exit 0 on the judged image, both surfaces on that digest.
- oss/release/ regenerated; fresh-clone install rehearsed (PC_REHEARSE=1).
- Docs contain no claim the code doesn't support; no secret or key material in any published file.
- SEC-11 / SEC-15 documented as known-open in the security status page.



Configuration options & open items

The configuration matrix (what the diagram encodes)

Configuration knob	home	dual	work
models.fleet_mode (console chat)	no model call	API-key transports	keyless Vertex, project-billed
Model API keys held by control plane	none	none	none
Vertex advisors (Opus / Gemini / Grok)	off	available	available
GE seats need a pasted model key?	n/a	no	no
Billing lands on	—	vendor of key	the project

Identity is orthogonal to the model: GE seats, Cowork and Grok each bring their own model via the connector; the fleet makes no model call on that path. Vertex is only reached by the console's 'work' mode and the advisors, keyless and project-billed. Session keys, IAP approver identity, connector (client_id+email) and SA id-tokens all resolve to a strain server-side — a key is a credential, never a role name.

Open by design (not blockers)

SEC-11 — promote the rehearsed artifact

Prod rebuilds the image instead of promoting the digest the gate judged. Same root cause as the MCP-surface drift. Fix is a pipeline change; until then, deploy the judged digest to both surfaces by hand and re-read BUILD_COMMIT.

SEC-15 — per-URL principal

Bearer stickiness can't work on a stateless MCP transport; the real fix is a per-URL principal (/mcp/:token), a design change, not a patch.

Also queued, non-blocking: arm VACUOUS_BUDGET=0 (one green run measured 1 vacuum control); regenerate oss/release/ on the next cut.